

Google Cloud Deployment & Infrastructure Blueprint

Target: Production / Staging Cloud Deployment on Google Cloud Platform (GCP)
Compiled for: Akshay Uppar (Lead Deployment Engineer) & Engineering Leadership
Date: 25 September 2026 • **Baseline:** GCP Native (ADR-18 Ratified)

Executive Context & Mandate: ZoikoShield has completed native GCP migration (ADR-18 ratified). All AWS KMS and S3 client dependencies have been replaced with Google Cloud KMS and Google Cloud Storage native Object Retention Lock. To satisfy the CTO Assurance Review (Lennox Report) and pass the remaining **NOT_RUN** gates (Live DR drills, regional cell verification, live pentests, and Cloud KMS HSM key custody), the platform must be provisioned and deployed on real GCP infrastructure. This document provides the authoritative, non-localhost specification, real environment variables, and operational constraints.

1. Microservices Architecture & Container Runtime

All 6 microservices build from the backend/ monorepo into individual container images stored in Artifact Registry. They deploy to **Cloud Run** or **GKE** with the following specifications:

Service	Port	Role & Key Responsibilities	GCP Sizing / Min Instances	Critical Runtime Constraints
shield-core	3001	System of record. Identity, auth, tenants, cases, alerts, detection, evidence, commercial API.	2 vCPU, 4GB RAM min-instances ≥ 1	Must NOT scale to zero. Runs Kafka outbox scheduler every 10s. Egress to internet (SMTP, ZoikoID) + Private Google Access.
shield-ingest	3002	High-throughput telemetry intake. Webhook / connector ingestion, OCSF normalization, quarantine.	2 vCPU, 2GB RAM min-instances ≥ 1	Must NOT scale to zero. Runs Kafka consumer loops. Ingestion capacity is ~60 events/sec per instance (scale horizontally).
shield-ai	3003	AI copilot, guardrails, policy enforcement, Gemini / Vertex AI model routing with safe fallback.	1 vCPU, 1GB RAM min-instances = 0/1	Stateless HTTP service. Needs internet/VPC egress to reach Google Generative AI / Vertex AI endpoints.
shield-action	3004	Governed response. Action proposals, 4-eyes / approval quorum, simulation, signed command receipts.	1 vCPU, 2GB RAM min = 1, MAX = 1	CRITICAL: HARD CAP AT MAX 1 INSTANCE. Approval quorum state & action locks are in-memory. Multi-instance loses pending approvals.
shield-anchor	3005	Evidence anchoring. Merkle tree checkpoints, witness receipts, Cloud KMS / PQC dual signing.	1 vCPU, 1GB RAM min-instances = 0/1	Needs Private Google Access to Cloud KMS for asymmetric P-256 signing.
frontend	3000	Next.js 14 Web Application & Operator Cockpit. Proxies /api/v1/* to backend services.	1 vCPU, 1GB RAM min-instances ≥ 1	Behind Cloud Load Balancing / Cloud Armor. WEBHOOK_HMAC_SECRET must match backend exactly.
shield-core-migrate	N/A	One-shot database migration job. Runs Prisma deploy + TypeORM SQL migrations.	Cloud Run Job (Exit on complete)	MUST execute and exit with code 0 before shield-core or any service boots.

2. Database Architecture (Cloud SQL for PostgreSQL 16)

ZoikoShield utilizes **one single PostgreSQL 16 database** (shield_core) partitioned across **four schemas** and managed by **two ORMs**. All migrations must be applied sequentially via npm run migrate:deploy.

Schema Name	ORM Manager	Managed Objects & Models	Critical DB Engine Rules & Gotchas
-------------	-------------	--------------------------	------------------------------------

public	Prisma	231 models (events, detections, alerts, cases, evidence records, controls, commercial, telemetry)	39 Prisma migrations in backend/prisma/migrations/. Requires direct connection for DDL.
identity	TypeORM	Principals, user credentials, sessions, passkeys (WebAuthn), federation, IAM policy documents	20 TypeORM SQL migrations in backend/typeorm-migrations/. Checksummed in public.infra_schema_migrations.
"authorization"	TypeORM	Roles, permissions, tenant memberships, invitations, JIT access elevations	RESERVED KEYWORD WARNING: authorization is a SQL keyword. Raw queries MUST quote it (e.g. "authorization".tenant_memberships).
tenant	TypeORM	Tenants, legal entities, environments, customer profiles, organization units	Foreign keys enforce strict multi-tenant partition across regional cells.

Cloud SQL PostgreSQL 16 Prerequisites:

1. Required Extensions: CREATE EXTENSION IF NOT EXISTS "uuid-oss"; and CREATE EXTENSION IF NOT EXISTS "pgcrypto";
2. Private IP & SSL: Connect via Serverless VPC Connector or Cloud SQL Auth Proxy. When using sslmode=require, the Node.js pg driver auto-enables TLS.
3. PgBouncer / Connection Poolers: TypeORM migrations split statements for transaction-mode PgBouncer, but Prisma migrations require a direct port 5432 connection.

3. Google Cloud Services to Create (Infrastructure Checklist)

The deployment engineer (Akshay) must provision the following native GCP managed services. All configuration is declared in `infrastructure/tofu/regional-cell/`:

GCP Managed Service	Instance / Resource Name	Tier / Configuration Details	Access & Network Topology
Cloud SQL for PostgreSQL	zs-{env}-pg-16	PostgreSQL 16, 2+ vCPU, 8GB RAM, SSD storage, automated backups & point-in-time recovery (PITR)	Private IP only (VPC). Accessible via Serverless VPC Access connector or GKE private nodes.
Memorystore for Redis	zs-{env}-redis	Redis 7.x, 2GB+ Memory, Standard Tier (HA with replica in secondary zone for failover)	Private IP only. Connected via default VPC peering.
Managed Kafka (or GKE Redpanda)	zs-{env}-kafka-cluster	Google Managed Service for Apache Kafka (or Redpanda cluster). Mechanism: oauthbearer.	Authenticated via ambient Google Service Account (roles/managedkafka.client).
Cloud Storage (Evidence Vault)	zs-{env}-evidence-vault-{region}	CRITICAL: Must enable --enable-per-object-retention, --uniform-bucket-level-access, and versioning.	Encrypted with Cloud KMS CMEK. Mode: Locked. No bucket-wide retention policy (per-object retention only).
Cloud KMS KeyRing & Keys	KeyRing: zoikoshield (4 Keys inside)	1. anchor-checkpoint (Asymmetric EC_SIGN_P256_SHA256) 2. evidence-collector (Asymmetric EC_SIGN_P256_SHA256) 3. action-command (Asymmetric EC_SIGN_P256_SHA256) 4. subject-key-wrapping (Symmetric ENCRYPTION)	HSM protection level recommended for production. Keys 1-3 take version resource names; Key 4 takes bare key name.
Artifact Registry	zoikoshield-docker	Standard Docker Repository in regional location (e.g. europe-west3 or us-central1)	IAM access for CI/CD Cloud Build and Cloud Run / GKE image pulling.
Secret Manager	zs-{env}-* secrets	Stores JWT_SECRET, WEBHOOK_HMAC_SECRET, SSO keys, DB credentials. Injected as env vars into Cloud Run.	Service accounts assigned roles/secretmanager.secretAccessor.
Serverless VPC Access	zs-{env}-vpc-connector	IP Range: 10.8.0.0/28, min 2 instances, max 10 instances (e2-micro)	Enables Cloud Run services to route private traffic to Cloud SQL, Redis, and Kafka.

4. Authoritative Real GCP Environment Variables

Rule: No localhost or 127.0.0.1 in production/staging. Omit optional environment variables rather than passing empty strings ("" overrides code defaults).

Variable Name	Real GCP Value Pattern / Example	Target Service	Description & Exact Formatting Requirement
NODE_ENV	production (or staging)	All Services	Activates strict production mode (dev signers throw on construction).
SERVICE_NAME	shield-core / shield-ingest / ...	Per Service	Distinct per service. Required to issue 60s workload identity tokens.
DATABASE_URL	postgres://shield:SECRET@10.10.0.3:5432/shield_core?sslmode=require	shield-core, migrate	Cloud SQL Private IP. Replace SECRET with fresh DB password.
REDIS_URL	redis://10.10.1.5:6379	shield-core, ingest	Memorystore Redis Private IP.
KAFKA_BROKERS	bootstrap.zs-cluster.region.managedkafka.proj.cloud.goog:9092	core, ingest, action	Managed Kafka bootstrap endpoint (comma-separated if multi-broker).
KAFKA_SASL_MECHANISM	oauthbearer	core, ingest, action	Uses attached GCP Service Account. No username/password needed.

GOOGLE_CLOUD_PROJECT	zs-production-proj	core, ingest, anchor	GCP Project ID hosting KMS and GCS Evidence Vault.
EVIDENCE_GCS_BUCKET	zs-prod-evidence-vault-europe-west3	shield-core, ingest	GCS Bucket created with Object Retention Lock enabled.
ANCHOR_KMS_KEY_VERSION	projects/P/locations/L/keyRings/zoikoshield/cryptoKeys/anchor-checkpoint/cryptoKeyVersions/1	shield-anchor	MUST include /cryptoKeyVersions/N (Asymmetric signing).
COLLECTOR_KMS_KEY_VERSION	projects/P/locations/L/keyRings/zoikoshield/cryptoKeys/evidence-collector/cryptoKeyVersions/1	shield-core	MUST include /cryptoKeyVersions/N (Evidence collector signature).
ACTION_COMMAND_KMS_KEY_VERSION	projects/P/locations/L/keyRings/zoikoshield/cryptoKeys/action-command/cryptoKeyVersions/1	shield-action	MUST include /cryptoKeyVersions/N (Governed response command signing).
SUBJECT_KEY_KMS_KEY_NAME	projects/P/locations/L/keyRings/zoikoshield/cryptoKeys/subject-key-wrapping	shield-core	DO NOT append version. Symmetric cryptoKey name for crypto-shredding.
JWT_SECRET	\$(openssl rand -hex 48)	shield-core	Cryptographically secure secret for user session tokens.
WEBHOOK_HMAC_SECRET	\$(openssl rand -hex 48)	frontend, ingest	MUST BE IDENTICAL in frontend and backend to forward webhooks.
SHIELD_CORE_BASE_URL	https://shield-core-prod-xxx-ew.a.run.app	frontend, satellites	Real Cloud Run internal URL or VPC Service Directory DNS.

5. Step-by-Step GCP Deployment Commands for Akshay

Execute these commands in the Google Cloud SDK shell (or apply via infrastructure/tofu/regional-cell/):

Step 1: Create Cloud KMS KeyRing and Keys

```
gcloud kms keyrings create zoikoshield --location=europe-west3
for KEY in anchor-checkpoint evidence-collector action-command; do
  gcloud kms keys create $KEY --keyring=zoikoshield --location=europe-west3 \
    --purpose=asymmetric-signing --default-algorithm=ec-sign-p256-sha256
done
gcloud kms keys create subject-key-wrapping --keyring=zoikoshield --location=europe-west3 --purpose=encryption
```

Step 2: Create GCS Evidence Bucket with Object Retention Lock

```
gcloud storage buckets create gs://zs-prod-evidence-vault-europe-west3 \
  --location=europe-west3 --enable-per-object-retention --uniform-bucket-level-access
gcloud storage buckets update gs://zs-prod-evidence-vault-europe-west3 --versioning
```

Step 3: Create Cloud SQL PostgreSQL 16 & Enable Extensions

```
gcloud sql instances create zs-prod-pg-16 --database-version=POSTGRES_16 --cpu=2 --memory=8GB \
  --region=europe-west3 --no-assign-ip --network=projects/PROJ/global/networks/VPC_NAME
gcloud sql databases create shield_core --instance=zs-prod-pg-16
# Connect via psql and execute: CREATE EXTENSION "uuid-oss"; CREATE EXTENSION "pgcrypto";
```

Step 4: Execute Database Migrations (One-shot Job)

```
gcloud run jobs create shield-core-migrate --image=europe-west3-docker.pkg.dev/PROJ/zoikoshield-docker/shield-core:latest \
  --command="npm","run","migrate:deploy" --vpc-connector=zs-prod-vpc-connector --region=europe-west3
gcloud run jobs execute shield-core-migrate --wait
```

Step 5: Deploy the Microservices (with Scaling Locks)

```
# shield-core (min-instances=1, no CPU throttling)
gcloud run deploy shield-core --image=../shield-core:latest --min-instances=1 --no-cpu-throttling ...
# shield-action (CRITICAL: min-instances=1, max-instances=1)
gcloud run deploy shield-action --image=../shield-action:latest --min-instances=1 --max-instances=1 ...
# shield-ingest (min-instances=1, horizontal scale as needed)
gcloud run deploy shield-ingest --image=../shield-ingest:latest --min-instances=1 --no-cpu-throttling ...
```

6. Status of CTO Review Gaps & Testing Prerequisite

A critical analysis of the Lennox CTO Assurance Review indicates that the engineering core is sound (410/410 tests green, ADR-18 ratified, native KMS/GCS implemented). However, **live cloud deployment is the mandatory prerequisite** to resolve the remaining P0 and P1 audit gates:

Gate / Gap ID	CTO Concern	Current Status	Why Live GCP Deployment is Required
P0-01 Cloud Drift	AWS vs GCP baseline ambiguity.	RESOLVED (ADR-18 ratified)	Google Cloud is formally ratified; native GCP KMS and GCS implemented in codebase.
P0-02 Live Cell	No live regional-cell proof; tofu plan is intent only.	NOT_RUN (Blocked on deploy)	Akshay must apply the OpenTofu regional cell to verify routing, health, and VPC isolation.
P0-04 Security	External penetration testing & red-teaming absent.	NOT_RUN (Blocked on deploy)	Independent ethical hackers require real, running HTTPS staging endpoints on GCP.
P0-05 DR Proof	1,326-record drill was reconciliation, not full DR.	NOT_RUN (Blocked on deploy)	Requires executing actual point-in-time recovery on Cloud SQL and GCS under live load.
P0-08 PQC & KMS	Ephemeral keys used in CI; production key custody unproven.	NOT_RUN (Blocked on deploy)	Requires testing against real Google Cloud KMS HSM asymmetric signing keys.
P1-09 Ingest Scale	Ingestion load test measured ~60/sec vs 15k envelope.	FAIL (Needs live cluster)	Must benchmark distributed multi-replica shield-ingest against Managed Kafka on GCP.

7. Deployment Handover Summary for Akshay

Immediate Action Items for Akshay:

1. **Create GCP Resources:** Cloud SQL (Postgres 16 + uuid-oss/pgcrypto), Memorystore Redis, Cloud Storage (Object Retention), Cloud KMS (4 keys), VPC Connector.
2. **Configure Secret Manager:** Generate new 48-byte hex secrets for JWT_SECRET, WEBHOOK_HMAC_SECRET, SSO_TRANSACTION_ENCRYPTION_KEY.
3. **Run Migration Job:** Execute gcloud run jobs execute shield-core-migrate and verify exit code 0.
4. **Deploy Cloud Run Services:** Enforce min-instances=1 on core/ingest/action, and **cap shield-action at max-instances=1**.
5. **Provide Live Endpoints to Team:** Export HTTPS service URLs to enable the QA/Security team to run live DR drills, load tests, and G1 certification.